

Vibe-Pythonpass: Comprehensive Cyber Security Risk Assessment

- **Executive Summary:** Overall risk posture: MEDIUM (down from HIGH after recent security improvements)
- **Identified Threats & Risks**

1. Data Breach (Stored Credentials Exposure)

- Severity: CRITICAL
- Likelihood: LOW (with current controls)
- Impact: Very High (loss of user credentials, regulatory fines, reputation damage)
- Mitigation:
 - AES-256 encryption at rest
 - Isolated key management (keys never touch application layer)
 - Regular penetration testing
 - Bug bounty program
 - Security audits quarterly
 - Monitoring for unauthorized database access attempts
- Residual Risk: LOW

2. Account Takeover via Phishing

- Severity: HIGH
- Likelihood: MEDIUM
- Mitigation:
 - Mandatory 2FA for all users (coming in v1.3)
 - FIDO2 hardware key support
 - Login anomaly detection
 - Email verification for account changes

- Residual Risk: MEDIUM

3. Man-in-the-Middle (MITM) Attacks

- Severity: HIGH
- Likelihood: LOW
- Mitigation:
 - TLS 1.3 enforced
 - HSTS header with 1-year preload
 - Certificate pinning in mobile apps
- Residual Risk: LOW

4. Supply Chain Attacks (Dependency Vulnerabilities)

- Severity: MEDIUM
- Likelihood: MEDIUM
- Mitigation:
 - Dependency scanning on every build
 - Minimal dependency footprint
 - Vendor security questionnaires
 - Software composition analysis (SCA) tools
- Residual Risk: MEDIUM

5. Insider Threats (Employee Malicious Actions)

- Severity: CRITICAL
- Likelihood: LOW
- Mitigation:
 - Zero-knowledge architecture (employees can't access unencrypted data)

- Background checks for security team
- Principle of least privilege for database access
- Audit logging of all admin actions
- Separation of duties for key management

- Residual Risk: LOW

- **Compliance Status**

- GDPR: Compliant
- SOC 2 Type II: In progress (audit scheduled Q2 2026)
- CCPA: Compliant
- HIPAA: Not applicable (not healthcare-focused)